

API Security with Tyk: Authentication & Authorization

Tyk secures your APIs by verifying who's making a request (AuthN)
and what they're allowed to do (AuthZ).

What Is Authentication (AuthN)?

Authentication means proving your identity.

In Tyk, when a request comes in, it checks who is calling the API. This is usually done using:

- API Keys – A unique string like a password
- JWT tokens – Signed tokens that include identity and permissions
- OAuth clients – Used in modern identity systems like Google or Microsoft
- mTLS (Mutual TLS) – Certificates to verify client identity

Example:

A user sends a request with an API key — Tyk checks “Is this a valid key?”

- Objective of AuthN: Confirm who you are.

What Is Authorization (AuthZ)?

Authorization means checking what you're allowed to do.

Once Tyk knows who you are, it checks your Access Rights:

- Can you call this API?
- Can you access this version of the API?
- Are you within the allowed rate limit or quota?

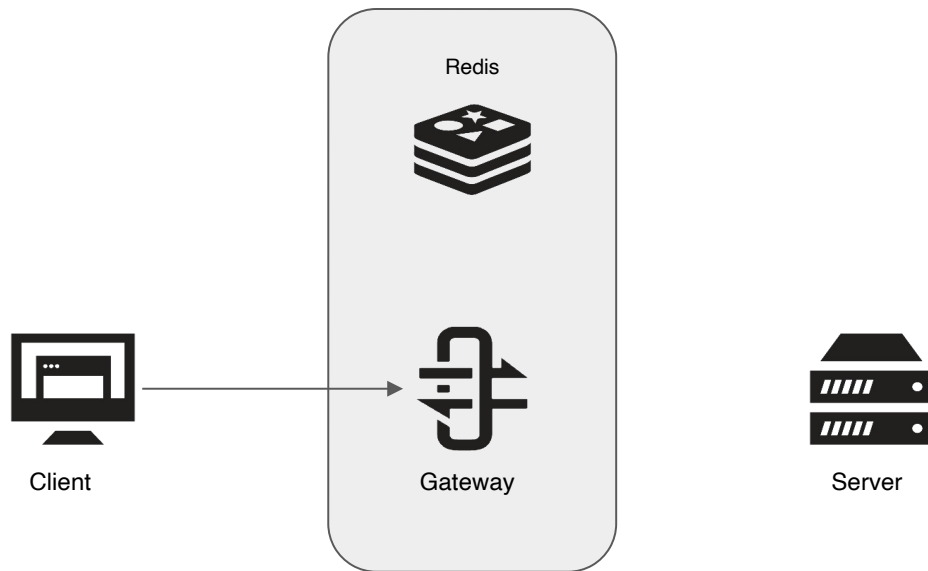
Example:

Even if a user has a valid key, Tyk checks, “Does this key allow access to the /admin API?”

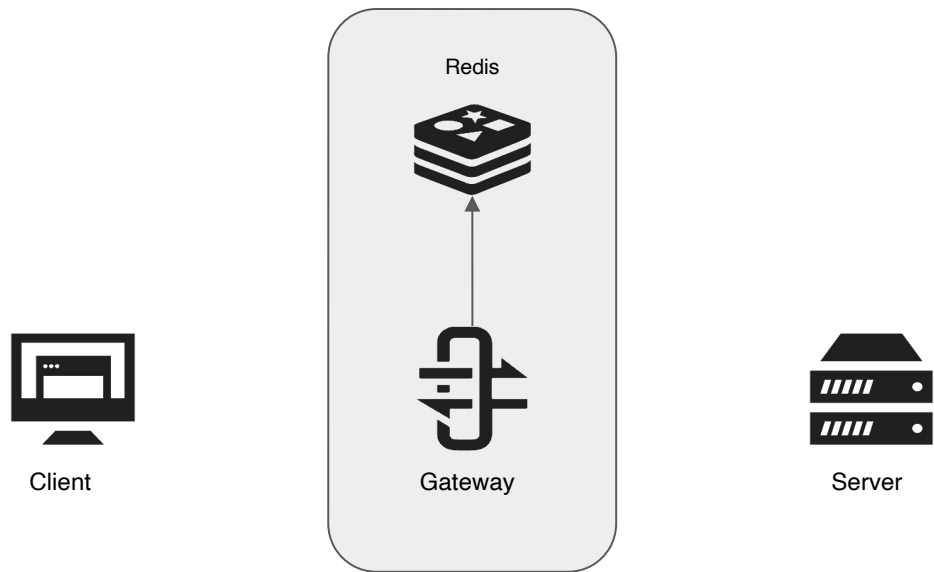
- Objective of AuthZ: Decide what you're allowed to do.

API Request Flow

1. A request is made to an API behind Tyk Gateway.

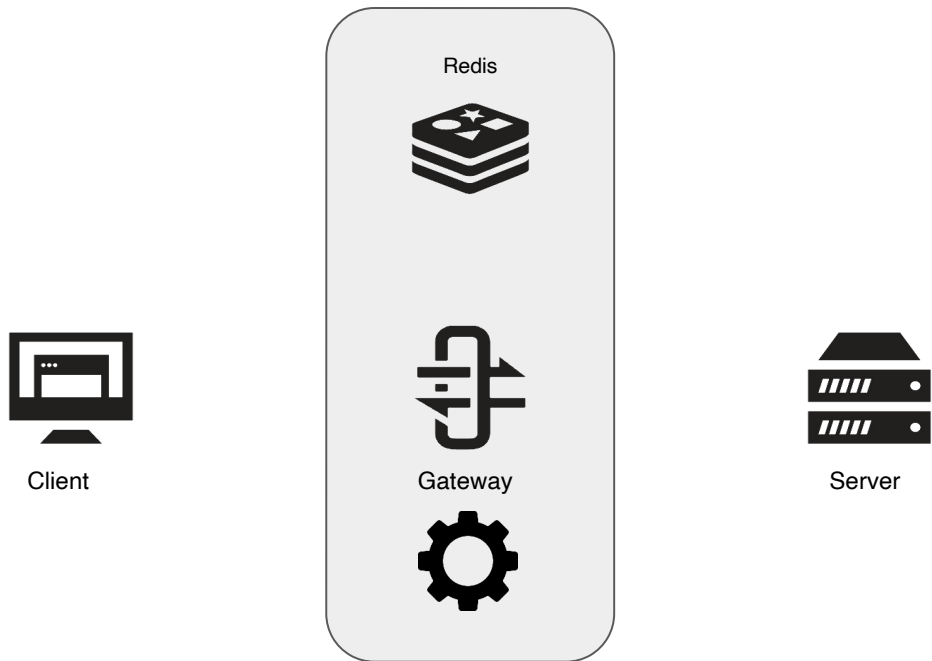


API Request Flow



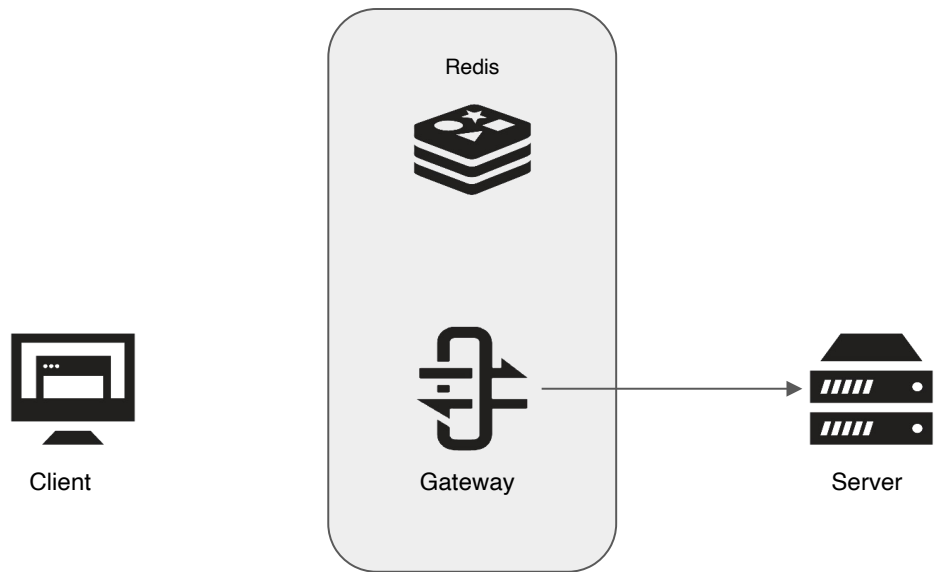
1. A request is made to an API behind Tyk Gateway.
1. Tyk authenticates the request (using API Key, JWT, OAuth, or mTLS).

API Request Flow



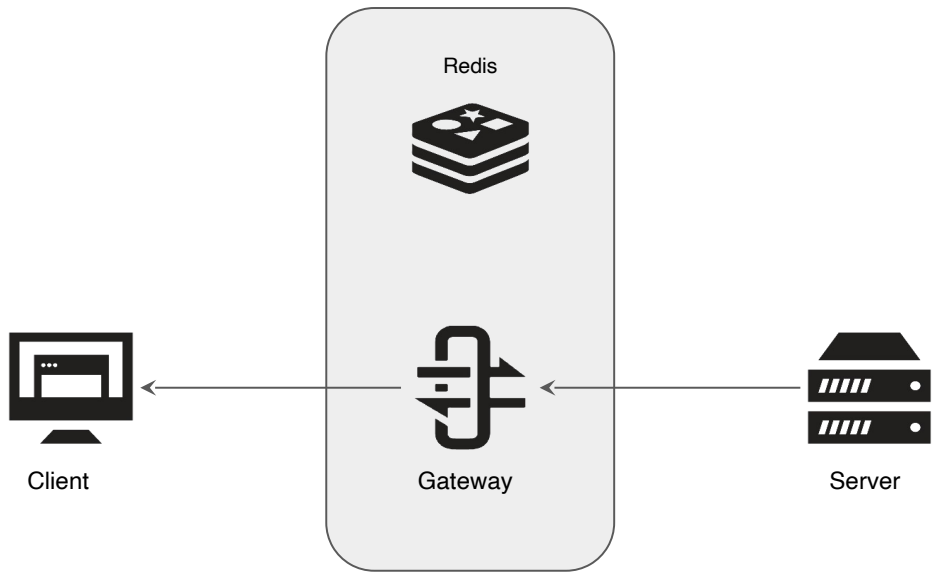
1. A request is made to an API behind Tyk Gateway.
1. Tyk authenticates the request (using API Key, JWT, OAuth, or mTLS).
1. If authentication succeeds, Tyk then authorizes the request:
 - a. Is this client allowed to call this API?
 - b. Are they within rate limits?

API Request Flow



1. A request is made to an API behind Tyk Gateway.
1. Tyk authenticates the request (using API Key, JWT, OAuth, or mTLS).
1. If authentication succeeds, Tyk then authorizes the request:
 - a. Is this client allowed to call this API?
 - b. Are they within rate limits?
1. If both checks pass, the request is forwarded to the API.

API Request Flow



1. A request is made to an API behind Tyk Gateway.
1. Tyk authenticates the request (using API Key, JWT, OAuth, or mTLS).
1. If authentication succeeds, Tyk then authorizes the request:
 - a. Is this client allowed to call this API?
 - b. Are they within rate limits?
1. If both checks pass, the request is forwarded to the API.
1. If either check fails, Tyk blocks the request with an error (e.g., 403 Forbidden or 401 Unauthorized).

How Tyk Applies Security

There are a wide array of options for authentication and authorizing access to APIs with Tyk.

These are configured as part of API definitions via:

- Gateway REST API in headless open-source installations
- or the Dashboard API or API Designer UI when using the Tyk Dashboard
- Config-as-code via Tyk Operator